

impact, l'Istituto ha dichiarato di non aver effettuato una valutazione di impatto specifica per i progetti di ricerca in corso, ritenendo che non fosse necessaria in quanto il trattamento dei dati avviene in conformità all'art. 110-bis, comma 4 del Codice.

2. Conclusioni

Alla luce di quanto emerso durante l'attività ispettiva, si evidenzia che l'Istituto Tumori Giovanni Paolo II di Bari ha adottato alcune misure per garantire la protezione dei dati personali, ma sono state riscontrate delle lacune significative in relazione agli obblighi di informativa e alla valutazione di impatto. Pertanto, si raccomanda all'Istituto di:

- a) Rivedere e aggiornare le procedure di informativa ai pazienti, assicurando che siano chiare e complete, in particolare per quanto riguarda il trattamento dei dati per scopi di ricerca;
- b) Effettuare una valutazione di impatto per i progetti di ricerca in corso, in conformità con le disposizioni del Regolamento e del Codice, per garantire che i diritti e le libertà degli interessati siano adeguatamente protetti;
- c) Implementare misure aggiuntive per garantire la trasparenza e la responsabilità nel trattamento dei dati personali, in particolare per quanto riguarda i pazienti deceduti o non contattabili.

3. Disposizioni finali

Il presente provvedimento sarà pubblicato sul sito web del Garante per la protezione dei dati personali e sarà trasmesso all'Istituto Tumori Giovanni Paolo II di Bari per le opportune valutazioni e azioni correttive.

Roma, 17 luglio 2024

Il Presidente

Prof. Pasquale Stanzione

impact, as referred to in Article 35 of the Regulation (Vip), the Institute has stated that, in general terms, it is conducted only for certain types of studies, which involve a particular type of profiling on patient data or if there are implications for their treatment through automated processes. The Institute also declared that in relation to Study 2) the Vip was not conducted, as it "uses both clinical data and characteristics extracted from radiomic images (simulation CT scans) that patients undergo in radiotherapy (where the patient has signed informed consent also for further treatment for research purposes)."

With specific reference to the data retention period within Study 2), the Institute stated that "the protocol indicates that the recruitment phase and the Study have a duration of 24 months, linked to the duration of the funding" and that "the research data in raw format must remain available in this form indefinitely for activities of control over the scientific validity of the data, reserving the right, if possible, to corroborate this assertion with specific documents."

Regarding the flow of data, the Institute declared that clinical data are manually entered into the e-crf, using data from paper medical records, as the electronic medical record is not conclusive since "it may not be complete and does not represent the reference legal medical document." The manual data entry phase into the e-crf "is often corroborated by a double check (Pi [Principal Investigator] and data manager). Each patient is assigned a progressive code; given the small number of patients enrolled in Study 2, the correlation list remains in the possession of the PI in paper format. The e-crf and the correlation table, where in electronic format, are both password protected, encrypted, and stored in two different partitions."

Also in relation to Study 1), the Institute stated that since it is a retrospective study, the legal basis for processing has been identified in Article 110-bis, paragraph 4 of the Code. In any case, both for the prospective phase and for the retrospective phase, if the patient is alive and contactable, consent is still obtained. In this regard, it has been generally represented that the choice to base the processing of personal data on Article 110-bis, paragraph 4 of the Code or on the consent of the data subjects is based on the prospective or retrospective nature of the study; where there is a deceased or

uncontactable patient, the processing is based on Article 110-bis, paragraph 4 of the Code. In any case, if possible, consent from the data subject is always obtained, particularly in retrospective studies.

The Institute, with reference to Study 1), also represented that the residual risk of processing has been considered low and that for this reason, as for Study 2), the Vip was not conducted, pursuant to Article 35 of the Regulation. In any case, for this last study, it was clarified that “neither deceased patients nor uncontactable patients have been enrolled, as only the prospective phase of the Study has been conducted to date.” With specific reference to the Vip, it was further represented that “it is prepared for studies where the risk identified by the PI in collaboration with the DPO requires such Vip. If drafted, it is submitted to the Ethics Committee. In the case where the Study enrolls a limited number of patients, it is not assessed as high risk and therefore the VIP is not prepared.”

In this regard, it was clarified that the responsible physician for the project is required to complete an attachment describing how the data are processed by the researchers (Attachment B) and that based on what is indicated by the physician in the aforementioned attachment, it is evaluated whether or not to carry out the Vip. In the context of the inspection activity, the Office has also acquired numerous documents containing internal guidelines with indications on the technical and organizational measures implemented by the Institute for the application of the regulations regarding the protection of personal data, as well as some information notices prepared for the data subjects.

From a first perspective, the Institute has represented that currently organizational measures far outweigh technical measures and that staff have undergone training activities on personal data protection. With specific reference to the transparency of the treatments, the following were provided: the information form on the processing of personal data carried out in the context of healthcare services, issued at the patient's admission to the hospital facility, for care purposes, in which, in the section on the purposes of processing, “the activities of medical, biomedical, and epidemiological research” carried out based on “Article 9, paragraph 2, letter a) of the GDPR (acquisition of consent): Article 9, letter j) of the GDPR “the processing is necessary for scientific research purposes based on Union or national law (in cases of untraceable or deceased patients) and Article 110-bis, paragraph 4 of Legislative Decree No. 196/03”; the informed consent form for the processing of personal data, in which a section is provided with the following wording “I consent to the use of my personal data for research purposes in the field of for the purpose of” followed by two fields to be filled in “yes” or “no” in which the patient is also informed that “before the start of each Study I may be contacted again to provide further specific consent to provide further specific consent.”

****Information Sheet and Informed Consent for the Study 2)**** which contains a section titled “Information and Expression of Consent for the Processing of Personal Data.” This information sheet states that “as of May 25, the new General Data Protection Regulation (GDPR) has come into effect, replacing Resolution 52 of 24/07/2008 Guidelines for the Processing of Personal Data in Clinical Trials of Medicines, in order to more thoroughly describe your rights [...]”.

It is also indicated that “at the end of the study, your personal data will be stored at the clinical center for the period required by current regulations.” In the section “Your Specific Rights Regarding Your Personal Data,” it is stated that the data subject “has the right to review your personal data. However, during the Study, access to personal data may be limited to protect the integrity of the Study. You will be able to access personal data at the end of the study.”

It is also provided that “questions regarding the collection and use of information should [be directed] to the Study physician. You should also inform them if you wish to exercise your rights regarding such information; for example, if you decide to correct some personal data or withdraw consent.” There is then a section where the data subject gives consent for the processing of personal data for research purposes; the documentation related to Studies 1) and 2): study protocol, information sheet, and informed consent containing a specific section related to privacy information and consent for the processing of personal data, and Annex B, completed by the responsible physician of the project.

The Institute has also transmitted further documentation regarding the “storage of research data in raw format for control activities on the scientific validity of the data” (note from XX). In this regard, the

Institute has specifically stated that: "Research data 'raw data' (numerical data, symbols, texts, images, etc.), used as primary sources of scientific research necessary to validate the results of the same research, are stored with appropriate technical and organizational security measures and suitable techniques for pseudonymization/anonymization."

In the context of clinical trials of medicinal products for human use (Reg. 536/14), the data retention period is observed for 25 years. In general, for each research project, the data retention period is defined, considering that this IRCCS, if at the end of the Study it deems it appropriate not to delete the archived data as they are considered a heritage of interest for scientific research (secondary use ex art. 110-bis c.4 of the Code), may retain them, pursuant to art. 5 of EU Regulation 2016/679, for a longer period, in accordance with the provisions of art. 89 of the GDPR;

Changes to the retention periods of personal data in the context of research are always subject to maximum informational transparency (ex arts. 13-14 of the GDPR).

****2. Alleged Violations****

Based on the elements acquired during the aforementioned inspection activity as well as subsequent evaluations carried out, the Office - with act of XX (prot. n. XX), which must be understood as fully reproduced here - has initiated, pursuant to art. 166, paragraph 5 of the Code, a procedure for the adoption of the measures referred to in art. 58, paragraph 2 of the Regulation, against the Institute, inviting it to produce to the Authority defensive writings or documents and to request to be heard by the Authority (art. 166, paragraphs 6 and 7, of the Code, as well as art. 18, paragraph 1, law no. 689 of November 24, 1981).

With the aforementioned act, the Office notified the Institute that it has been established that the processing of personal data carried out by it for research purposes in the medical, biomedical, and epidemiological fields within its research lines and in particular in Studies 1) and 2), has been carried out in violation of:

1. arts. 5, paragraph 1, letter a) and 9, paragraph 2 letter j) of the Regulation, 110 and 110-bis, paragraph 4 of the Code;
2. art. 35 of the Regulation;
3. arts. 12, 13 and 14, paragraph 5 letter b) of the Regulation and art. 6, paragraph 3 of the Ethical Rules;
4. art. 5, paragraph 1, letter e) of the Regulation;
5. arts. 5, paragraph 2, and 25 of the Regulation.

More specifically regarding each of the aforementioned violations, the Office has noted the following.

****2.1. On the Principle of Lawfulness and Legal Bases of Processing****

In relation to the processing of personal data concerning health, including where applicable genetic data, for scientific research purposes carried out by the Institute within the research lines authorized by the Ministry of Health and in particular for those analyzed during the inspection - Study 1) and Study 2) - as highlighted above, the legal basis has been identified in art. 110-bis, paragraph 4 of the Code, subject to obtaining consent in the event that the patient is alive and contactable (present in the informed consent forms of the aforementioned Studies) and also subject to the consent obtained in any case during healthcare services.

In this regard, the Office of the Authority has considered that, in general terms, there is a partial understanding on the part of the Institute of the conditions of lawfulness related to the processing of personal data concerning health.

health and genetics for medical, biomedical, and epidemiological research purposes, which inevitably reflects in their application, in the performance of related obligations, and in the information provided to the interested parties.

The Institute, on one hand, declares and informs the interested parties at the acceptance stage within the hospital structure that the further processing of data collected for care purposes carried out for research purposes is based on Article 110-bis, paragraph 4 of the Code, while on the other hand, it

systematically fails to carry out and publish the impact assessment (mandatory obligations in this case, according to the regulatory reconstruction indicated in the subsequent paragraph 3 and already illustrated to the Institute with notes dated XX, prot. n. XX and dated XX, prot. n. XX).

The Institute, however, has simultaneously declared and demonstrated that the aforementioned processing is also based on the consent of the interested parties (where it is materially possible to obtain it) collected at the acceptance stage and subsequently also during the enrollment of patients in specific research projects.

On these grounds, in relation to the collection and subsequent processing of data from deceased and non-contactable patients enrolled exclusively in Study 2), given that it was declared during the inspection that enrollment was ongoing, the Institute was contested for failing to fulfill the obligation to carry out and publish the impact assessment in violation of Articles 110 first part of paragraph 1 and 110-bis, paragraph 4 of the Code (Article 166, paragraph 2 of the Code).

The same contestation was not made in relation to Study 1) as it was declared that "neither deceased patients nor non-contactable patients have been enrolled, as only the prospective phase of the Study has been conducted to date."

The violation of the principle of lawfulness, as per Article 5, paragraph 1, letter a) of the Regulation, was also contested in relation to the processing of personal data concerning deceased or non-contactable subjects enrolled in the retrospective studies conducted by the Institute within its research lines, to the extent that the latter, as the data controller, has systematically failed to carry out and publish the impact assessment, obligations that are mandatory in this case, pursuant to Articles 9, paragraph 2, letter j) of the Regulation, 110, paragraph 1, first part, and 110-bis, paragraph 4 of the Code.

From the investigations carried out, it also emerged that the Institute, with particular reference to the processing of personal data of contactable patients for medical, biomedical, and epidemiological research purposes, collects two different consents, the first of which is obtained during healthcare services and appears to authorize the processing of data for medical research purposes in certain areas, without prejudice to the possibility of obtaining further consent for specific projects.

In this regard, the Office noted the inadequacy of such a manifestation of will, particularly regarding specificity, to allow the aforementioned processing as the field of scientific research to be indicated in the consent form only identifies macro purposes of the research itself and not a specific project.

Furthermore, since such consent is not preceded by a complete information notice at least regarding its essential elements, it would be fundamentally flawed in terms of specificity and determinateness (Articles 13 of the Regulation; see points 23 et seq. of the Guidelines on transparency pursuant to Regulation 2016/679, adopted on November 29, 2017, amended version adopted on April 11, 2018).

This collection of consent has therefore been considered in contrast with the principles of transparency and fairness as per Article 5, paragraph 1, letter a) of the Regulation, as, although in practice the subsequent processing of data for scientific research purposes is based on a new manifestation of consent or on Article 110-bis paragraph 4 of the Code, it has been deemed likely to generate confusion among the interested parties regarding the fate of their data, in violation of the principle of informational self-determination and thus of fairness and transparency.

2.2. On the impact assessment

With regard to the necessity of conducting a prior impact assessment on the processing of personal data for medical research purposes, the Institute stated that it only carries out this obligation when the study involves a particular type of profiling on patient data or if there are implications for their care through automated processing, based on the assessment carried out by the trial office/PI reported in the above-mentioned document titled Annex B) acquired in the proceedings. The document does not contain the examination and assessment of the risks associated with the processing but only a description of some aspects of the same, including, in particular, the types of data collected, the legal basis for the processing, and some generic technical and organizational measures.

In this regard, the Office noted how the Institute restricts the conduct of the impact assessment to a number of cases far fewer than those for which it, even if not required by law pursuant to the combined provisions of Articles 110 and 110-bis paragraph 4 of the Code, is nevertheless necessary pursuant to Article 35 of the Regulation.

Considering that, in general terms, for the realization of clinical studies in the medical, biomedical, and epidemiological fields, the sponsor as the data controller processes health data (and, if applicable, also genetic data, data suitable for revealing racial and ethnic origin, or relating to life and...

on sexual orientation) concerning vulnerable subjects, such as patients and/or minors, it is observed that in such cases the failure to carry out the Vip in advance should be considered exceptional and should be extensively justified (p. 13 of the Guidelines of October 4, 2017, cited), in homage to the principle of accountability, whereas the rule should instead be to fulfill this obligation.

On these bases, it has been noted that the Institute does not duly consider the centrality of the risk-based approach imposed by the Regulation, omitting as a general rule, and particularly in reference to the data of patients enrolled or intended to be enrolled in Studies 1) and 2), to carry out the Vip, in violation of Article 35 of the Regulation.

****2.3 On the principle of transparency and the obligation to provide information to the data subjects****

The Institute has stated that it provides patients with general information on the processing of data at the time of their admission to the hospital for care reasons, attaching a copy of it, and then provides the enrolled subjects in the clinical studies with further specific information regarding the related processing, providing copies of those related to Studies 1) and 2).

The first information concerns the processing of personal data carried out within the framework of the healthcare services offered by the Institute. The Office has noted its incompleteness in relation to some elements of Article 13 of the Regulation. Through this information, in any case, the Institute anticipates to the data subjects that the data collected for care purposes may be further processed for research purposes, pursuant to Article 110-bis, paragraph 4 of the Code or based on the relevant consent pursuant to Article 9, paragraph 1, letter a) of the Regulation.

However, this does not exempt the data controller from the duty to provide specific information regarding each individual research project, at least to provide information that differs from that already disclosed to the data subjects (Articles 13, paragraph 3 and 14, paragraph 5, letter b) of the Regulation). This further information, however, for deceased or uncontactable subjects, is systematically not provided, in violation of Article 14, paragraph 5, letter b) of the Regulation and Article 6, paragraph 3 of the Ethical Guidelines. The Institute has indeed stated that, for such patients, the information is that provided at the time of the patient's admission to its facility for the provision of healthcare services.

**In fact, it is reiterated that the data controller has the obligation to provide information directly to the data subjects in advance if possible, or through their publication if they are deceased or uncontactable (Article 14, paragraph 5, letter b) of the Regulation and Article 6, paragraph 3 of the Ethical Guidelines). It has also been noted that the information on the processing of personal data related to Studies 1) and 2) prepared for contactable subjects has proven to be entirely similar in content and incorrect and incomplete in the part where: it is indicated that following the entry into force of the Regulation it would have replaced the resolution 52 of 24/7/2008 containing the "Guidelines for the processing of personal data in the context of clinical trials of medicines, in order to describe more detailed rights [...]"; in fact, the aforementioned guidelines remain in force where compatible with the Regulation; they do not clearly indicate the legal bases for the processing (Article 13, paragraph 1, letter c) of the Regulation); they do not indicate the period of retention of personal data nor the criteria used to determine it (Article 13, paragraph 2, letter a) of the Regulation), despite the Institute having stated on this point that "Changes in the retention periods of personal data in the context of research are always subject to maximum transparency (ex Articles 13-14 of the GDPR; see note from the Institute of XX)"; the rights of the data subjects and the ability to revoke consent are not clearly

represented; the possibility of exercising access to the data is only provided at the end of the Study. This limitation is not provided for by the current regulatory framework (see also the "Guidelines 01/2022 on data subject rights - Right of access", Version 1.0, Adopted on January 18, 2022).**

In consideration of the above, the Office has therefore contested the violation of the obligation to provide clear, complete, and easily understandable information in advance to contactable data subjects regarding the processing of personal data necessary for the realization of Studies 1) and 2), in violation of Articles 12 and 13 of the Regulation. Furthermore, the violation of the obligation to publicly disclose information on the processing of personal data concerning deceased and uncontactable subjects enrolled in Study 2) has been contested, in violation of Article 14, paragraph 5, letter b) of the Regulation and Article 6, paragraph 3 of the ethical guidelines.

Finally, for the reasons stated above, a violation by the Institute of the principle of transparency has been noted, considering the preparation of incomplete or erroneous information forms, the total absence of organizational measures or a specific policy to publicly disclose information on the processing for research purposes of the personal data of deceased or uncontactable data subjects.

2.4. On the limitation of data retention

During the inspection assessment, it was finally found that, on one hand, the information provided to the data subjects during the acceptance phase at the hospital facility indicates that the retention period for data processed for research purposes should be specified in the relevant protocols. On the other hand, not only is this period not defined (at least in the protocols related to Studies 1 and 2 and also not in the informational documents addressed to the data subjects), but the criteria for its determination are also not indicated. The aforementioned terms are also not defined in the "Privacy Guidelines for the Processing of Personal Data for Scientific Research Purposes."

In this regard, the regulations on personal data protection in no case exempt the data controller from the obligation to define the retention period for the data or a suitable criterion for that purpose, particularly in order to comply with the specific transparency obligations towards the data subjects. Therefore, it has been established that the Institute processes personal data for scientific research purposes in violation of the principle of data retention limitation as per Article 5, paragraph 1, letter e) of the Regulation.

2.5. On the Principle of Accountability and Privacy by Design and by Default

Based on all that has already been noted, the violation of the principles of accountability and privacy by design as per Articles 5, paragraph 2, and 25 of the Regulation has also been established, as the data controller has not generally demonstrated an active conduct aimed at ensuring, from the design stage and by default, the effective application of the principles of personal data protection (in particular, those of lawfulness, fairness, and transparency, and of data retention limitation) through the implementation and constant review and updating of specific, adequate, and measurable measures, also in relation to the particular context in which the processing operations examined take place and the related risks to the rights and freedoms of the data subjects.

The Institute has indeed produced a substantial amount of documentation prepared in the field of privacy, particularly with reference to the resolutions of the General Director approving the "Regulation for the Protection of Personal Data of Natural Persons, in Compliance with EU Regulation 2016/679 (GDPR)" and the "Privacy Guidelines for the Processing of Personal Data for Scientific Research Purposes" (resolution 1100 of December 27, 2019).

In this regard, it has also been observed that the aforementioned documents may be considered mere organizational measures, more formal than substantive, and ineffective in themselves if not corroborated by further technical and organizational measures identified in relation to the specific processing carried out by the controller and proportionate to the protection objective that is intended to be pursued.

Moreover, in the referenced documents, inaccurate or at least incomplete indications have emerged, for example, regarding retention periods or the further processing for scientific research purposes of personal data collected for care purposes—for which no reference is made to Article 110-bis, paragraph 4 of the Code, as the legal basis for processing, nor to the specific obligations required of

the controller (such as the conduct and publication of the VIP).

The lack of adequate technical security measures has, on the other hand, been confirmed by the same controller who, during the investigation, stated that "currently, organizational measures are far more prevalent than technical ones and reserves the right to provide proof of the training activities carried out."

In this regard, the absence of adequate technical measures to ensure by design the accuracy of the data during the collection phase for the pursuit of further research purposes within monocentric studies has been particularly noted. As highlighted above, the data loading phase into the e-CRF is manual, although "often corroborated by a double check (PI and data manager)."

It has also been noted that despite the Privacy Guidelines for the Processing of Personal Data for Scientific Research Purposes adopted by the Institute expressly stating that an audit for compliance with them should be conducted by a committee at the "start-up" of each research project, it was not possible to acquire the audit reports conducted on Studies 1) and 2) during the inspection assessments.

For all the above observations, the failure of the Institute to effectively apply the principle of accountability and the obligations of personal data protection by design has been noted, in violation of Articles 5, paragraph 2, and 25 of the Regulation.

****3. The applicable regulations****

The processing of personal data for scientific research purposes must be carried out in compliance with the Regulation and the Code, the Provisions relating to the processing of genetic data (if necessary), and the Provisions relating to the processing of personal data carried out for scientific research purposes (doc. web no. 9124510), as well as the Ethical Rules (doc. web no. 9069637) which constitute an essential condition for the lawfulness and fairness of the processing (Article 2-quater of the Code and Article 21, paragraph 5, of Legislative Decree August 10, 2018, no. 101).

According to the Regulation, personal data must be processed "lawfully, fairly, and transparently in relation to the data subject."

****(principle of "lawfulness, fairness, and transparency" (art. 5, par. 1, lett. a) of the Regulation).****

The principle of lawfulness requires that any processing is based on a specific legal basis (art. 6 of the Regulation). In relation to particular categories of data, including health data, art. 9 of the Regulation establishes a general prohibition on processing unless one of the specific exemptions to this prohibition applies, among which is the consent of the data subject.

In cases where the condition of lawfulness is represented by consent, it must be given through a positive act by which the data subject expresses a free, specific, informed, and unequivocal will regarding the processing of personal data concerning them (Recitals 32, 42, and 43, arts. 5, 6, par. 1, lett. a) and 7 of the Regulation and Guidelines 5/2020 on consent under Regulation (EU) 2016/679, adopted by the European Data Protection Board on May 4, 2020).

With specific reference to particular categories of data, consent must also be expressed in writing (art. 9, par. 2 lett. a) of the Regulation and par. 4 of the aforementioned Guidelines 5/2020 on consent and art. 7, par. 2, lett. b) of the Ethical Rules).

On this point, it is noted that the European Data Protection Board has reiterated that "the notion of research cannot be extended beyond its common meaning and that for 'scientific research' in this context, it is understood as a research project established in accordance with the relevant methodological and ethical standards, in line with good practices," thereby confirming that in this sector the purpose of processing must be identified in the specific research project that is intended to be carried out (Guidelines 5/2020 on consent cited; "A preliminary Opinion on scientific research" of the European Data Protection Supervisor, cited).

Without undermining the obligations related to consent, recital 33 of the Regulation acknowledges that "In many cases, it is not possible to fully identify the purpose of the processing of personal data for scientific research at the time of data collection. Therefore, data subjects should be allowed to give their consent to certain areas of scientific research where there is compliance with recognized ethical standards for scientific research. Data subjects should have the option to give their consent only to certain areas of research or parts of research projects to the extent permitted by the intended

purpose." It therefore admits, in residual circumstances, that data subjects may give consent in phases for the processing of personal data for scientific research purposes when it is not possible to fully identify the specific purposes of the processing at the time of collection. This is considering that, even in relation to the processing in question, it is not possible to derogate from the requirement of specificity and granularity of consent (arts. 6 and 7 of the Regulation and point 7.2 of Guidelines 5/2020 on consent cited).

In such cases, therefore, the data controller is subsequently required to define one or more specific research projects in accordance with the ethical and methodological rules of the sector and integrate the expressions of will of the data subjects already collected, with specific consents to progressively obtain a legal basis suitable for the processing of data for scientific research purposes (arts. 5, par. 1 lett. a) 6, 7, and 9 of the Regulation; Guidelines 5/2020 on consent, cited; see also "A Preliminary Opinion on data protection and scientific research" of the European Data Protection Supervisor, dated January 6, 2020; "Document on response to the request from the European Commission for clarifications on the consistent application of the GDPR, focusing on health research" adopted by the European Data Protection Board on February 2, 2021), or, where it is in one of the conditions referred to in art. 110 of the Code and point 5.3 of the Provisions, to carry out the obligations referred to in art. 110 of the Code as amended by art. 44, par. 1-bis of the decree-law of March 2, 2024, no. 19, converted with law of April 29, 2024, no. 56 and indicated by the Supervisor in the resolution promoting the new ethical rules for the processing of data for statistical and scientific research purposes (provision of May 9, 2024 doc. web 10016146).

For what is relevant here, it is also noted that the pursuit of scientific research purposes in the medical, biomedical, and epidemiological fields is permitted upon obtaining the consent of the data subject. "Consent is not necessary when the research is carried out based on provisions of law or regulation or Union law in accordance with article 9, paragraph 2, letter j), of the Regulation, including the case where the research falls within a biomedical or health research program provided for under article 12-bis of legislative decree December 30, 1992, no. 502, and an impact assessment is conducted and made public in accordance with articles 35 and 36 of the Regulation" (art. 110 of the Code, art. 9, par. 2, lett. j) and par. 4 of the Regulation).

With specific reference to the processing of personal data for scientific research purposes carried out by IRCCS, it is reiterated here, as already highlighted in the note of XX, prot. no. XX, which refers to art. 110-bis, par. 4, of the Code, according to which "The processing of personal data collected for clinical activity, for research purposes, by scientific hospitalization and care institutes, public and private, does not constitute further processing by third parties, due to the instrumental nature of the healthcare assistance activity carried out by the aforementioned institutes in relation to... research, in compliance with the provisions of Article 89 of the Regulation." Article 110-bis, paragraph 4 of the Code, must be read in conjunction with the sector-specific regulations for IRCCS, particularly as outlined in Legislative Decree No. 288 of October 16, 2003, and subsequent amendments, which provides for the "Reorganization of the regulations governing hospitals and healthcare facilities of a scientific nature" that identifies appropriate and specific measures to protect the fundamental rights and interests of the data subject (see, in particular, Article 8, paragraph 5-bis of Legislative Decree No. 288 of 2003).

It follows that Article 110-bis, paragraph 4 of the Code, provides IRCCS with a specific legal basis, under which, pursuant to Article 9, paragraph 2, letter j) of the Regulation, they may process the data collected for healthcare purposes also for further scientific research purposes in the medical, biomedical, and epidemiological fields without the need to obtain prior consent from the patients.

Therefore, Article 110-bis, paragraph 4 of the Code constitutes one of those "legal provisions" referred to in Article 110 (first part of the first paragraph) of the Code, which prescribes as an additional requirement for the processing of data for research purposes in the medical, biomedical, and epidemiological fields, carried out pursuant to Article 9, paragraph 2, letter j) of the Regulation, the performance and publication of the impact assessment, pursuant to Article 35 of the Regulation (see FAQ on the legal bases and main obligations for the processing by IRCCS of personal data collected for health care purposes for further research purposes dated May 6, 2024, web doc No. 10024215).

In any case, the principle of the alternative legal bases remains firm; therefore, in implementation of the principle of lawfulness, it is up to the data controller to identify, for each individual study, among the different lawful conditions provided for in Articles 6 and 9, paragraph 2 of the Regulation, the one that is concretely most appropriate, corresponding to the objective and essence of the processing, and consequently indicate it in the impact assessment and in the information provided to the data subjects, also taking into account the different implications that each of them may have on the rights of the data subjects (Articles 15-22 of the Regulation).

The principles of transparency and fairness imply that the data subject is to be informed in advance of the existence of the processing and its purposes, providing, in a concise, transparent, intelligible, and easily accessible form, using simple and clear language, the information referred to in Article 13 of the Regulation, in the case of data collected directly from them, or pursuant to Article 14 of the Regulation, in the case of data collected from third parties (recitals 58 and 60 and Articles 5, paragraph 1, letter a) and 12 of the Regulation).

It is particularly noted that the aforementioned regulations provide that, if the data has been previously collected for other purposes, as in the case at hand, the data controller must provide the data subject with information regarding that different purpose and any further relevant information before such further processing (Article 13, paragraph 4 of the Regulation).

In any case, regarding data not collected from the data subjects, the controller may refrain from providing the information to the extent that communicating it proves impossible or involves a disproportionate effort. This is particularly relevant in the context of processing carried out for scientific research purposes, without prejudice to the conditions and guarantees provided for in Article 89, paragraph 1 of the Regulation and the adoption of appropriate measures to protect the rights, freedoms, and legitimate interests of the data subject, including making the information public (Article 14, paragraph 5, letter b) of the Regulation and Article 6, paragraph 3 of the Ethical Guidelines).

Furthermore, the principle of data retention limitation is significant, which mandates that data be “kept in a form that permits identification of the data subjects for no longer than is necessary for the purposes for which the data are processed” (Article 5, paragraph 1, letter e) of the Regulation).

Among the principles applicable to processing established in Article 5 of the Regulation, the principle of accountability merits highlighting in this context, according to which “the data controller must comply with and be able to demonstrate compliance with the principles and obligations set forth in the Regulation” (Articles 5, paragraph 2, 24 of the Regulation).

This is linked to the duty to ensure that the rights and regulations regarding the protection of personal data of the data subjects are safeguarded and applied from the design stage and by default (privacy by design and by default, Article 25 of the Regulation).

In compliance with the obligation of data protection from the design stage, controllers must take an active approach in applying the principles, aiming to achieve a real protective effect. The requirement set forth in Article 25 of the Regulation obliges controllers to ensure that data protection is integrated into processing from the design stage and by default throughout the entire lifecycle of the processing.

The Regulation also provides that “when a type of processing, particularly when it involves the use of new technologies, considering the nature, scope, context, and purposes of the processing, may present a high risk to the rights and freedoms of natural persons, the data controller shall carry out, prior to proceeding with the processing...”

treatment, an assessment of the impact of the

proposed treatments on the protection of personal data. A single assessment may examine a set of similar treatments that present analogous high risks” (art. 35; Article 29 Working Party Guidelines No. 248 concerning “The data protection impact assessment and the criteria for determining whether a processing” adopted in amended form on 4.10.2017).

In particular, the impact assessment is

necessary whenever the processing may present a high risk to the rights and freedoms of natural

persons, particularly those that involve: i) the evaluation or assignment of a score; ii) automated decision-making that has legal effects or significantly affects the data subject in a similar manner; iii) systematic monitoring; iv) processing of sensitive data or data of a highly personal nature; v) processing of data on a large scale; vi) the creation of matches or combinations of data sets; vii) processing of data relating to vulnerable data subjects; viii) innovative use or application of new technological or organizational solutions; ix) processing that prevents data subjects from exercising a right or availing themselves of a service or a contract. In particular, the European Data Protection Board believes that a DPIA must certainly be conducted whenever at least two of the aforementioned criteria are simultaneously present (Part III, letter B) of the aforementioned Guidelines).

4. The defensive memoranda and assessments of the Authority

By note dated XX (prot. n.XX), the Institute submitted its defensive memoranda, not requesting to be heard in a hearing, as provided for by art. 166, paragraph 5 of the Code.

4.1. On the principle of lawfulness, fairness, and transparency

In relation to the allegations made by the Authority,

the Institute represented, with statements for which it is criminally liable under art. 168 of the Code, preliminarily that “in the context of the two studies, the subject of the allegations, the patient recruitment phase had not been initiated, as stated in the minutes [...], a determining circumstance for declaring the merely potential and theoretical nature of the possible harm from the alleged violations and, therefore, exempting, or at least strongly mitigating, the alleged violations.”

This statement, confirming what was already represented in relation to study 1), also clarifies the meaning of what was recorded following the inspections of XX, during which the Institute, regarding Study 2), stated that “[...]. The study is ongoing and the patient recruitment phase has not yet been completed. Currently, 58 potential patients have been identified, both living and deceased.”

In particular, with reference to the allegation of violation of the principles of transparency and fairness, linked to the circumstance that at the patient acceptance stage a preliminary and generic consent is collected from the data subjects for research purposes, the Institute represented that it intended to collect such consent by implementing

recital 33 of the Regulation, hypothesizing a sort of phased consent.

In this regard, notwithstanding the above highlighted in relation to the case referred to in the aforementioned recital 33 of the Regulation, taking into account the good faith of the data controller, which is widely evident from the submitted memoranda and in particular from the circumstance that, where possible, prior to the commencement of personal data processing for research purposes, the consent of the data subjects is nonetheless obtained, it is believed that the allegation of violation of the principles of transparency and fairness referred to in art. 5, par. 1,

letter a) of the Regulation is overcome.

4.2 On the impact assessment

With reference to the allegation of violation of the obligation to conduct a DPIA in relation to the processing of personal data necessary for the realization of clinical studies and in particular those examined during the inspection (study 1 and 2), the Institute defended itself by stating in particular that it is “preparing the assessment activities [of impact] certainly for those newly initiated and, in any case, also for the ongoing studies.”

While positively acknowledging the commitment made by the controller, it is noted, however, that the processing of personal data related to health and, if applicable, genetic data, concerning vulnerable subjects (such as patients) often carried out through combinations of data or on a large scale or through the use of new technologies (such as in Study 2, which specifically involves the use of artificial intelligence techniques for the analysis of clinical and imaging data), certainly falls among those for which a DPIA must be conducted in advance, pursuant to art. 35 of the Regulation (cf. Guidelines No. 248 cited, Part III, letter B). This is also relevant with specific reference to retrospective clinical studies that the Institute claims to base on art. 110-bis, paragraph 4 of the Code.

Furthermore, considering that the document following which it is decided at the Institute whether the

processing is worthy of a DPIA or not does not examine the risks related to the processing, no elements have emerged from the defensive memoranda that would overcome the allegation of violation of art. 35 of the Regulation.

In this last regard, it is noted that the circumstance that the Institute has not initiated the patient recruitment phase in Studies 1) and 2), while it may serve as a mitigating factor, is not in itself sufficient in this case to dismiss the alleged violation, as the DPIA by its nature same nature must be carried out before the start of the treatments and the documentation of the studies shows how the Institute conducted internal evaluations erroneously concluding that it did not need to carry out such compliance.

4.3 On the principle of transparency and the obligation to inform the interested parties

With reference to the challenge regarding the violation of the principle of transparency as per Article 5, paragraph 1, letter a) of the Regulation and the obligation to make public the information on the processing of personal data relating to deceased and uncontactable subjects enrolled in Study 2), as per Article 14, paragraph 5, letter b) of the Regulation and Article 6, paragraph 3 of the Ethical Rules, in its defensive memoranda, the Institute represented that it considered itself "satisfied precisely because of the double information provided to the patient, one at the first access to the Institute, the other at the start of the specific research for the individual project, in addition to the privacy information also provided on the Entity's website, in the page dedicated to this purpose" and that "all retrospective and prospective studies are published on the corporate website, in the form of a resolution of acknowledgment."

In this regard, while positively acknowledging the commitments made by the Institute concerning the informational obligations, no elements useful to overcome the challenge of the violation of the principle of transparency, as per Article 5, paragraph 1, letter a) of the Regulation, are found in the submitted memoranda, even in relation to the processing of personal data concerning deceased and uncontactable subjects due to the systematic omission of the obligation to publish the information pursuant to Article 14, paragraph 5, letter b) of the Regulation and Article 6, paragraph 3 of the Ethical Rules.

With reference, instead, to the information on data processing within healthcare services, supplementary documentation has been produced that proves how the previous one was incomplete, as it was missing the last page (3/3). The complete text containing all the information referred to in Articles 13 and 14 of EU Regulation 2016/679 has been transmitted to the records and is available in the dedicated Privacy section of the institutional website (<https://www.sanita.puglia.it/web/irccs/privacy1>).

It is therefore considered that the challenge regarding the violation of Articles 12 and 13 of the Regulation concerning the information provided at the time of patient acceptance has been overcome.

Finally, it should be noted that the challenges related to the information on the processing of personal data concerning Studies 1) and 2) prepared for contactable subjects, placed at the end of the documentation and the information preliminary to the collection of informed consent, have not been overcome. They are indeed found to be erroneous and incomplete according to what was contested by the Office of the Guarantor and recalled in the previous point 2.3.

For these reasons, the violation by the Institute of the principle of transparency is therefore established, taking into account the preparation of incomplete and/or erroneous informational forms and the total absence of organizational measures as well as a specific policy to make public the information on the processing for research purposes of the personal data of deceased or uncontactable interested parties (Article 5, paragraph 1, letter a) and 13 of the Regulation).

4.4 On the limitation of data retention

With reference to the challenge regarding the violation of the principle of limitation of data retention, the Institute represented that "the limitation of the retention period will be indicated in compliance with the law and taking into account the specificity of the case, as already specified above."

While positively acknowledging "the manifest willingness of the Entity to comply with the regulations concerning health and research regarding the correct processing of personal data" and the commitment made in this regard by the Institute, the violation of the principle of limitation of retention, as per Article 5, paragraph 1 letter e) of the Regulation, is nonetheless established for the reasons outlined above (cf. paragraph 2 or 3).

4.5 On the Principle of accountability and privacy by design and by default

Regarding the challenge of the Institute's failure to effectively apply the principle of accountability and the obligations of personal data protection by design, in violation of Articles 5, paragraph 2 and 25 of the Regulation), the latter, in its defense, requested the Authority to evaluate "benevolently the corporate system of the Entity" highlighting some specific actions that are intended to be undertaken.

On this basis, the Guarantor, while acknowledging the good faith of the Institute and the commitment already made to improve the technical and organizational measures aimed at ensuring effective application of the principles regarding personal data protection, nonetheless considers the violation of the obligations of personal data protection by design, in violation of Articles 5, paragraph 2 and 25 of the Regulation, to be established and confirmed for the reasons outlined above (cf. paragraph 2.5).

5. Conclusions

In light of the evaluations mentioned above, taking into account the statements made pursuant to Article 168 of the Code during the investigation and the elements provided by the data controller in the defensive memorandum, although deserving of consideration, do not allow, as illustrated and motivated above, to overcome most of the observations notified by the Office with the initiation of the procedure, nor do any of the cases provided for by Article 11 of the Regulation apply.

Garante n. 1/2019.

For these reasons, the illegality of the processing of personal data carried out by the Giovanni Paolo II Institute for Hospitalization and Scientific Care in Bari is noted as it violates Articles 5, paragraph 1, letter e), paragraph 2, 9, paragraph 2 letter j), Article 14, paragraph 5, letter b), 25, and 35 of the Regulation, as well as Article 110, paragraph 1, first part, and Article 110-bis, paragraph 4 of the Code, and Article 6, paragraph 3 of the Ethical Rules. The violation of the aforementioned provisions also makes the administrative sanction provided for in Article 83, paragraphs 4 and 5 of the Regulation applicable, pursuant to Articles 58, paragraph 2, letter i), and 83, paragraph 3, of the same Regulation and Article 166, paragraph 2 of the Code.

6. Corrective Measures

Article 58, paragraph 2 of the Regulation provides the Garante with a series of corrective powers, of a prescriptive and sanctioning nature, to be exercised in the event that an unlawful processing of personal data is established, including the power to "order the data controller or the data processor to bring the processing into compliance with the provisions of this regulation, if necessary, in a specific manner and within a specified time frame" (Article 58, paragraph 2 letter d) of the Regulation). In light of the evaluations mentioned above, it is deemed necessary to order the Institute, pursuant to the aforementioned Article 58, paragraph 2, letter d) of the Regulation, to adopt, within ninety days from the notification of this provision, the following corrective measures:

- to carry out the impact assessment pursuant to Article 35 of the Regulation and Articles 110 and 110-bis, paragraph 4 of the Code (paragraph 4.2);
- to publish the information regarding the processing of personal data related to deceased and non-contactable subjects, pursuant to Article 14, paragraph 5, letter b) of the Regulation and Article 6, paragraph 3 of the Ethical Rules (paragraph 4.3);
- to integrate, modify, and rectify the information on the processing of personal data related to Studies 1) and 2) prepared for contactable subjects (paragraph 2.3 and 4.3), in particular:
- eliminating the indication that following the entry into force of the Regulation, it would have replaced the resolution 52 of 24/7/2008 containing the "Guidelines for the processing of personal data in the context of clinical trials of medicinal products, in order to more thoroughly describe its rights [...]";
- clearly indicating the legal bases for the processing (Article 13, paragraph 1, letter c) of the Regulation);

- indicating the retention period of personal data or the criteria used to determine it (Article 13, paragraph 2, letter a) of the Regulation);
- clearly representing the rights of the data subjects and the ability to withdraw consent;
- providing the possibility to exercise the right of access for the entire duration of the processing.

7. Adoption of the injunction order for the application of the administrative pecuniary sanction and accessory sanctions (Articles 58, paragraph 2, letters i and 83 of the Regulation; Article 166, paragraph 7, of the Code).

The violation of Article 5, paragraph 1, letter e) and paragraph 2, of Article 9, paragraph 2, letter j), of Articles 13, 14, paragraph 5, letter b) and of Articles 25 and 35 of the Regulation, of Articles 110, paragraph 1, first part and 110-bis, paragraph 4 of the Code and of Article 6, paragraph 3 of the Ethical Rules committed by the Institute is subject to the application of the administrative pecuniary sanction, pursuant to Article 83, paragraph 4, letter a) and 5, letter a) and b) of the Regulation. The Garante, pursuant to Articles 58, paragraph 2, letter i) and 83 of the Regulation, as well as Article 166 of the Code, has the power to "impose an administrative pecuniary sanction pursuant to Article 83, in addition to the [other] corrective measures referred to in this paragraph, or in lieu of such measures, depending on the circumstances of each individual case" and, in this context, "the College [of the Garante] adopts the injunction order, which also provides for the application of the accessory administrative sanction of its publication, in whole or in part, on the Garante's website pursuant to Article 166, paragraph 7, of the Code" (Article 16, paragraph 1, of the Garante Regulation n. 1/2019).

The aforementioned administrative pecuniary sanction imposed, depending on the circumstances of each individual case, must be determined in amount taking into account the principles of effectiveness, proportionality, and deterrence, as indicated in Article 83, paragraph 1, of the Regulation, in light of the elements provided for in Article 83, paragraph 2 of the Regulation in relation to which it is noted that:

- the processing carried out particularly concerned information capable of revealing the health status of patients enrolled in the clinical studies conducted by the Institute within its research lines (Article 4, paragraph 1, numbers 13 and 15 of the Regulation and Article 83, paragraph 2, letters a) and g) of the Regulation);
- from the perspective concerning the subjective element, no intentional attitude on the part of the data controller emerges, as the established violations occurred in good faith (Article 83, paragraph 2, letter b) of the Regulation);
- there are no previous relevant violations committed by the data controller nor have any previous measures pursuant to Article 58 of the Regulation been imposed (Article 83, paragraph 2, letter e) of the Regulation);
- the Institute has shown itself to be cooperative during the inspection assessment and this proceeding;
- Despite the ongoing profiles of non-compliance with the current regulatory framework regarding the protection of personal data highlighted above, the Institute has already implemented some corrective measures concerning the processing of personal data carried out (Article 83, paragraph 2, letter c) of the Regulation).

In light of the aforementioned elements, assessed as a whole, it is deemed appropriate to determine the amount of the administrative fine provided for by Article 83, paragraphs 4 and 5, of the Regulation, in the amount of € 10,000.00 (ten thousand/00) for the violation of Article 5, paragraph 1, letter e), and paragraph 2, of Article 9, paragraph 2, letter j), of Articles 13, 14, paragraph 5, letter b) and of Articles 25 and 35 of the Regulation, of Articles 110, paragraph 1, first part and 110-bis, paragraph 4 of the Code and of Article 6, paragraph 3 of the Ethical Rules as an administrative monetary sanction deemed, pursuant to Article 83, paragraphs 1 and 3, of the Regulation, effective, proportionate, and dissuasive.

It is also considered that the accessory sanction of publication on the website of the Authority of this provision should apply, as provided for by Article 166, paragraph 7 of the Code and Article 16 of the Regulation of the Authority No. 1/2019, also considering the type of personal data subject to unlawful processing.

Finally, it is noted that the conditions referred to in Article 17 of Regulation No. 1/2019 concerning

internal procedures with external relevance, aimed at carrying out the tasks and exercising the powers entrusted to the Authority, are met.

ALL OF THE ABOVE, THE AUTHORITY

declares the unlawfulness of the processing of personal data carried out by the Institute of Tumors "Giovanni Paolo II" I.R.C.C.S., with legal headquarters at Viale Orazio Flacco 65, 70124 Bari (BA) - C.F and P.I.: 00727270720, for the violation of Article 5, paragraph 1, letter e), and paragraph 2, of Article 9, paragraph 2, letter j), of Articles 13, 14, paragraph 5, letter b) and of Articles 25 and 35 of the Regulation, of Articles 110, paragraph 1, first part and 110-bis, paragraph 4 of the Code and of Article 6, paragraph 3 of the Ethical Rules as stated in the reasoning.

ORDERS

pursuant to Articles 58, paragraph 2, letter i) and 83 of the Regulation, as well as Article 166 of the Code, the Institute to pay the sum of € 10,000.00 (ten thousand/00) as an administrative monetary sanction for the violations indicated in this provision. It is represented that the offender, pursuant to Article 166, paragraph 8, of the Code, has the option to settle the dispute by payment, within 30 days, of an amount equal to half of the imposed sanction.

COMMANDS

the Institute:

1. to pay the sum of € 10,000.00 (ten thousand/00) - in case of failure to settle the dispute pursuant to Article 166, paragraph 8, of the Code - according to the methods indicated in the annex, within 30 days from the notification of this provision, under penalty of the adoption of the consequent executive acts in accordance with Article 27 of Law No. 689/1981;
2. to comply with the processing provisions of the Regulation, adopting the corrective measures indicated in paragraph 6 of this provision, within and no later than 90 days from the notification of this provision, pursuant to Article 58, paragraph 2, letter d), of the Regulation. Non-compliance with an order issued pursuant to Article 58, paragraph 2, of the Regulation is punishable by the administrative sanction referred to in Article 83, paragraph 6, of the Regulation;
3. to communicate what initiatives have been undertaken in order to implement what is prescribed in the aforementioned paragraph 6) and to provide feedback, adequately documented, within and no later than 20 days from the expiration of the above-mentioned deadline, pursuant to Article 58, paragraph 1, letter a), of the Regulation and Article 157 of the Code. Failure to respond to a request made pursuant to Article 157 of the Code is punishable by the administrative sanction, pursuant to the combined provisions of Articles 83, paragraph 5, of the Regulation and 166 of the Code.

PROVIDES

pursuant to Article 166, paragraph 7 of the Code, the full publication of this provision on the website of the Authority and considers that the conditions referred to in Article 17 of Regulation No. 1/2019 concerning internal procedures with external relevance, aimed at carrying out the tasks and exercising the powers entrusted to the Authority, are met.

Pursuant to Article 78 of the Regulation, Articles 152 of the Code and 10 of Legislative Decree No. 150/2011, against this provision it is possible to appeal to the ordinary judicial authority, under penalty of inadmissibility, within thirty days from the date of communication of the provision itself or within sixty days if the appellant resides abroad.

Rome, July 17, 2024

THE PRESIDENT

Stanzione

THE REPORTER

Stanzione

THE SECRETARY GENERAL

Mattei